

ASSIGNMENT

Name : Mohammed Safwaan M

Reg No : 192421385

Course Name : Ethical Hacking

Course Code : ITA1407

Assignment : CO2-AT1

1. Nmap Network Scan Report Analysis

Introduction

Nmap (Network Mapper) is a network scanning tool used to identify open ports, running services, operating systems, and service versions on a target system. It helps security professionals identify vulnerabilities before attackers exploit them.

Report Analysis

The Nmap scan of 192.168.1.10 detected the following open ports:

- Port 22 (SSH): Secure remote login service.
- Port 80 (HTTP): Web server hosting websites or web applications.
- Port 3306 (MySQL): Database server for storing application data.
- Operating System and Service Versions: The scan also revealed the OS and software versions running on the target.

Security Risks

1. SSH (Port 22)

- Weak passwords may allow brute-force attacks.
- Outdated SSH versions may contain known vulnerabilities.
- Unauthorized access can lead to complete system compromise.

2. HTTP (Port 80)

- Websites may be vulnerable to SQL Injection, Cross-Site Scripting (XSS), or Directory Traversal.
- Data transmitted over HTTP is not encrypted.
- Attackers can gather server information from banners.

3. MySQL (Port 3306)

- Exposed databases may allow unauthorized access.
- Weak database credentials can result in data theft.
- Vulnerable MySQL versions may allow remote code execution.

2. GoPhish Phishing Campaign Report Analysis

Introduction

GoPhish is a phishing simulation tool used to evaluate employees' awareness of phishing attacks. It helps organizations identify users who are vulnerable to social engineering attacks.

Report Analysis

The phishing campaign results show:

- 40% of employees clicked the phishing link.
- 20% entered their login credentials.
- Several users downloaded a malicious attachment.

Security Weaknesses

1. High Click Rate (40%)

- Employees failed to recognize phishing emails.
- Lack of awareness about suspicious links.

2. Credential Submission (20%)

- Users trusted fake login pages.
- Poor understanding of website verification.

3. Malicious Attachment Downloads

- Employees opened unsafe email attachments.
- Lack of knowledge about malware risks.

Possible Attacks

- Credential theft leading to unauthorized access.
- Malware or ransomware infection through attachments.
- Business Email Compromise (BEC).
- Data theft and financial fraud.

Recommended Security Measures

1. User Awareness Programs

- Conduct regular phishing awareness training.
- Perform periodic phishing simulation exercises.
- Teach employees how to identify suspicious emails and URLs.

2. Email Security Controls

- Implement Spam Filters.
- Enable SPF, DKIM, and DMARC.
- Scan email attachments for malware.
- Block executable file attachments.

3. Organizational Policies

- Enforce Multi-Factor Authentication (MFA).
- Establish procedures for reporting suspicious emails.
- Conduct regular cybersecurity awareness sessions.
- Follow the principle of least privilege for user accounts.

Conclusion

The GoPhish report indicates that employees remain vulnerable to phishing attacks. Continuous security awareness training, advanced email protection, and strong organizational policies can significantly reduce successful social engineering attacks.

3. Dig DNS Assessment Report Analysis

Introduction

Dig (Domain Information Groper) is a command-line tool used to query DNS servers and retrieve DNS records. It helps administrators verify DNS configurations and identify security issues.

Report Analysis

The Dig assessment revealed that the organization's DNS server allows DNS Zone Transfer (AXFR), exposing:

- Internal hostnames
- Mail server information
- DNS records
- Network structure

Security Implications

- Attackers can obtain detailed information about the organization's internal network.
- Exposed mail server records assist phishing and email attacks.
- Internal hostnames reveal potential targets.
- Attackers can map the network before launching attacks.

Possible Attacks

- Network reconnaissance.
- Targeted phishing campaigns.
- Exploitation of exposed servers.
- DNS spoofing and further penetration attacks.

Security Recommendations

- Disable unauthorized DNS Zone Transfers.
- Allow AXFR only for trusted secondary DNS servers.
- Use Access Control Lists (ACLs) to restrict DNS requests.
- Enable DNSSEC to protect DNS integrity.
- Monitor DNS logs regularly.
- Keep DNS server software updated.

Conclusion

Allowing unrestricted DNS Zone Transfer exposes critical infrastructure information that attackers can use for reconnaissance. Restricting zone transfers, implementing DNSSEC, and regularly monitoring DNS servers greatly improve DNS security.